

Cyber Physical System Security

SC4015/CE/CZ4055

Automotive Cyber Security

Anupam Chattopadhyay
CCDS, NTU



Go to wooclap.com

Enter the event code in the top banner

Event code

SIJXCQ

Announcement

Dear Students,

The Smart Card Lab report details have been posted. All 3 assignments (2 Individual reports, and a Group Project Report) are due on **19th April, 2026**.

Thank you.

Best,

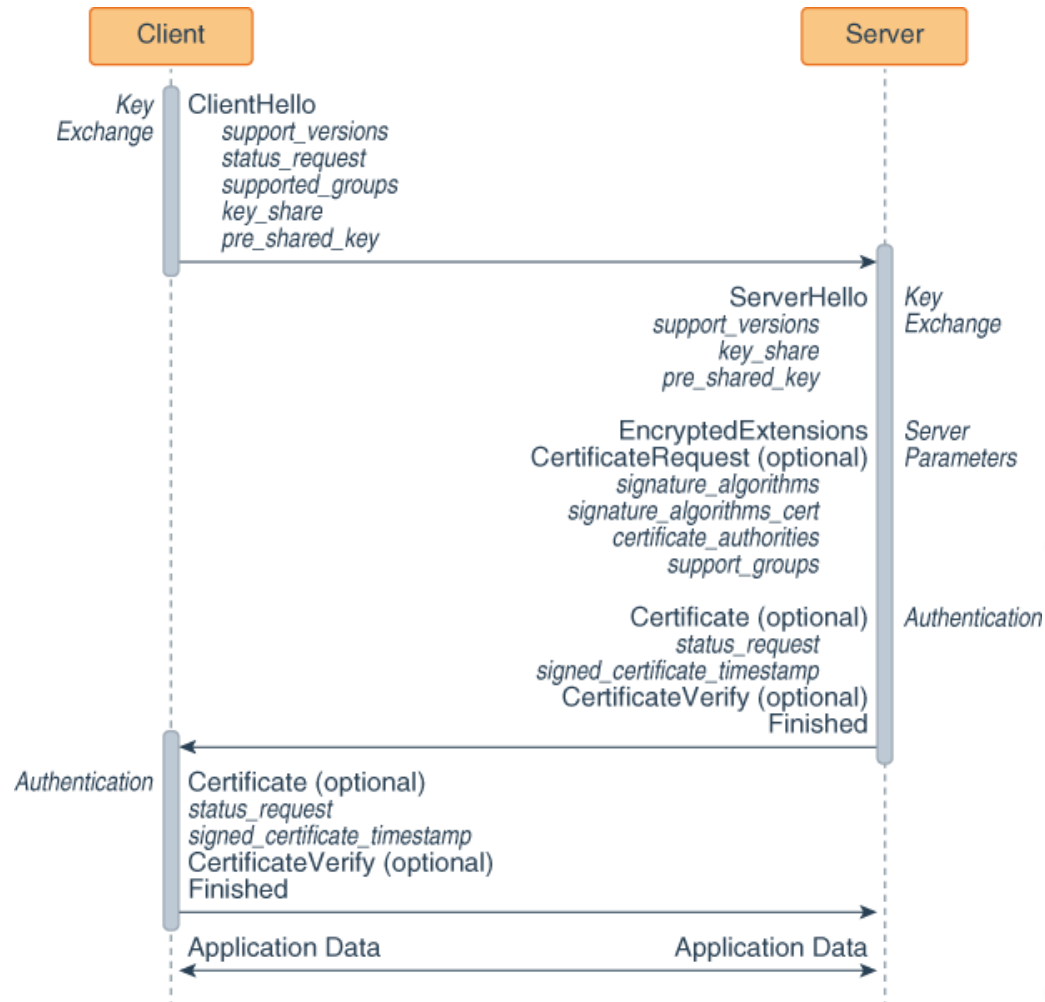
TAs of CE4055



REVISIT PAST LECTURE



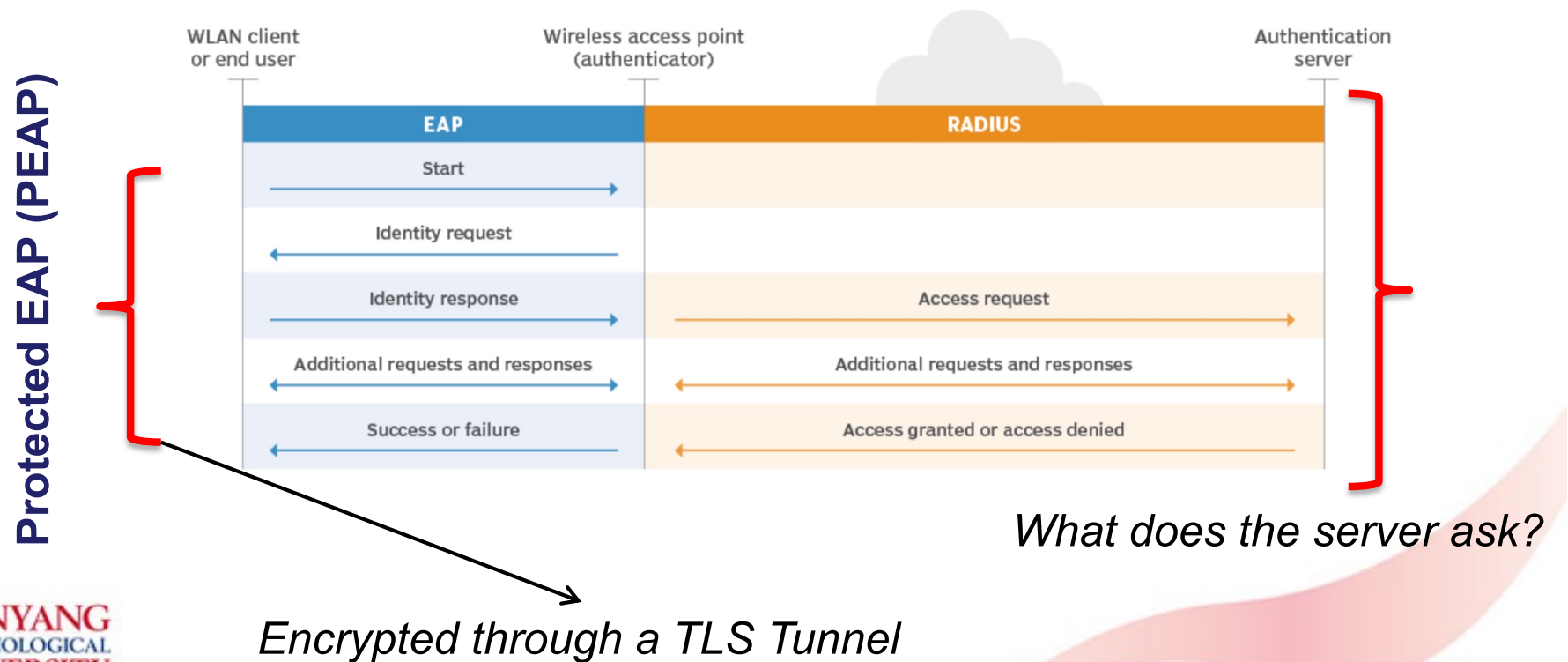
TLS 1.3 Protocol



How to authenticate?

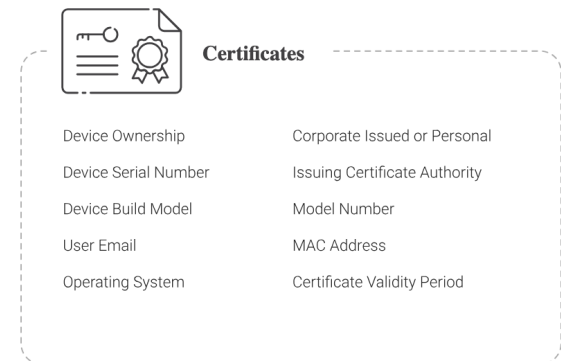
Extensible Authentication Protocol (EAP)

- Multiple variants in deployment for authenticating devices in a wireless network, including PEAP-TLS, PEAP-MSCHAPv2
- Defined within IEEE 802.1X



PEAP-MSCHAPv2 vs PEAP-TLS

- MSCHAPv2 is Microsoft's extension to the Challenge Handshake Authentication Protocol
 - Challenge-response is password-based, wrapped in MD4 Hash (*deprecated*)
 - Only client is authenticated, not server
- PEAP-TLS
 - Certificate-based validation
 - Device needs to be registered
- Flexible authentication frameworks, e.g., *GlobalProtect*





Go to wooclap.com

Enter the event code in the top banner

Event code

SIJXCQ

The BIG Picture

SECURE TRANSPORTATION

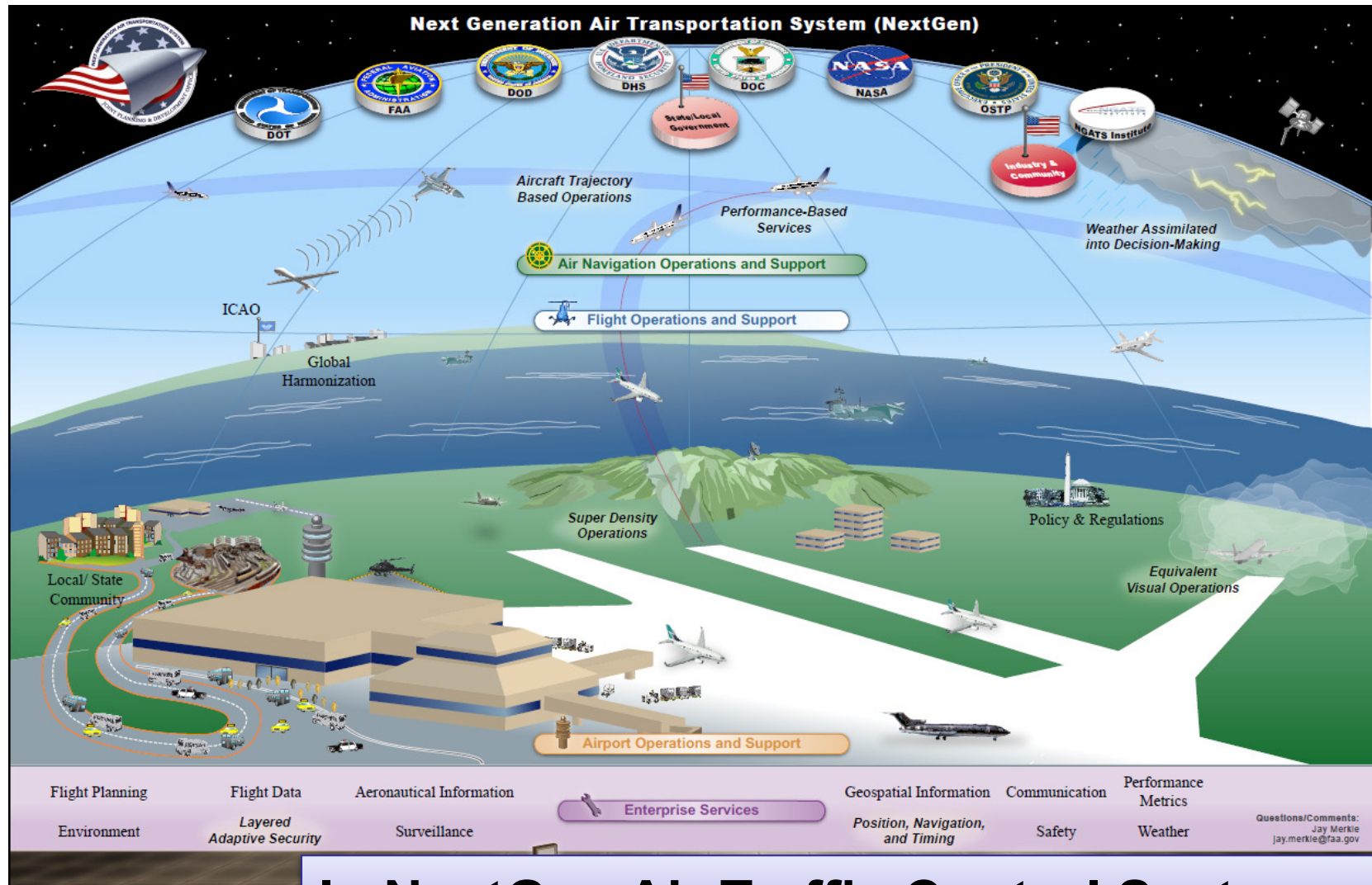
Intelligent Transportation Systems



Aug 13, 2022: The auto industry lost its spectrum fight with the Federal Communications Commission.

Europe and many other areas still have a wider spectrum of the 5.9GHz band reserved for V2V and V2X technologies, worldwide harmonisation on the issue is clearly vital in making a truly cohesive intelligent transport system

Dependence on the Digital Infrastructure



In NextGen Air Traffic Control Systems

Intermodal Ports



Terminal Operations & Management



Automated Gates



Physical Security



Crane Monitoring and Control



Wireless Devices & Tracking

Transit Vehicles are E-enabled and Autonomous

RF Cellular WiFi WiMAX DSRC

Control Domain

Vehicle Controls

Vehicle Diagnostics

Traffic Signal Priority

Video Surveillance

Vehicle Immobilizers



Operations Domain

Automated Dispatching

Vehicle Location

Route/Schedule Status

Passenger Counters

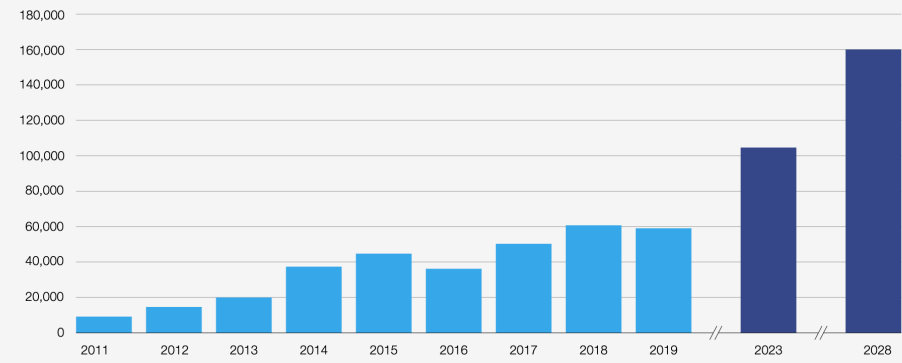
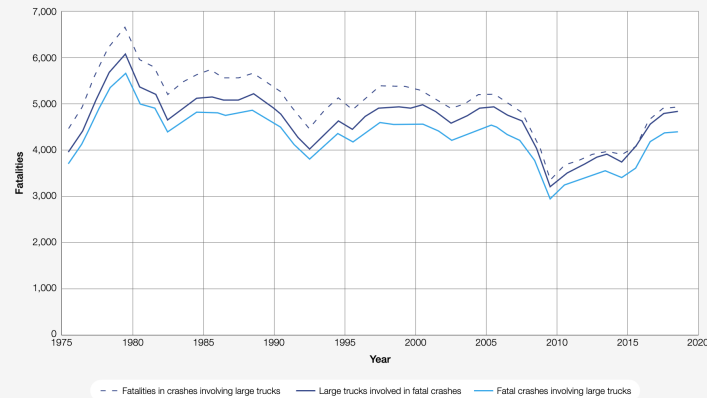
Electronic Payments

Infotainment Domain

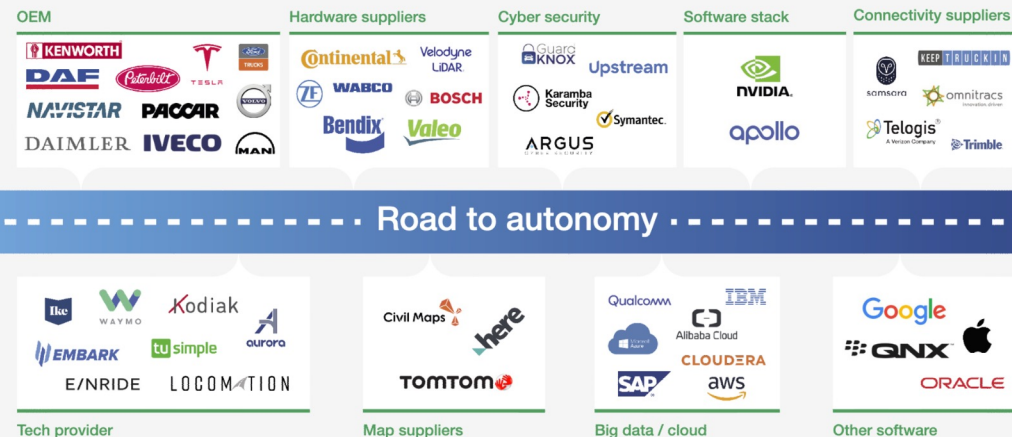
Customer use of WiFi and WiMAX

Real-time Travel Info, Trip Planning

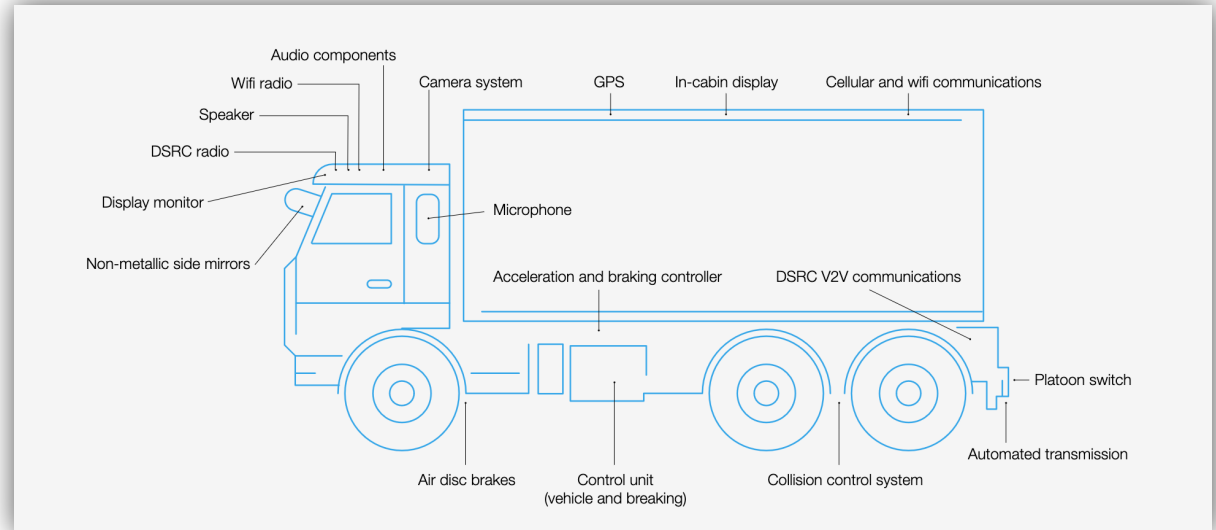
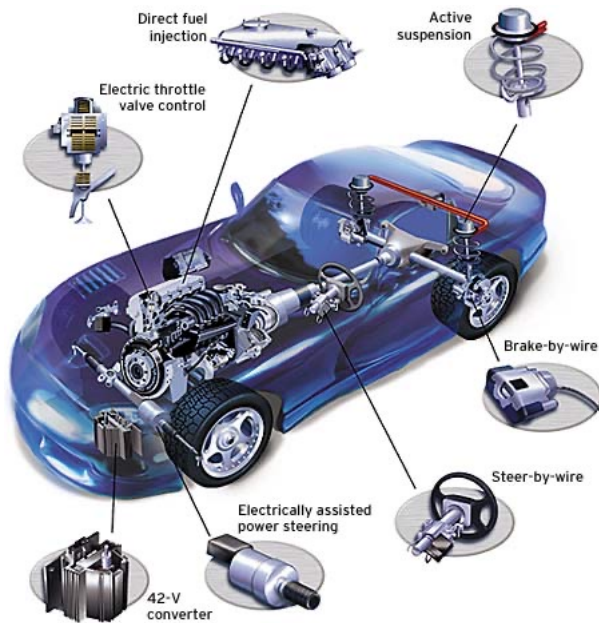
Autonomy addresses Fatalities, Driver Shortage



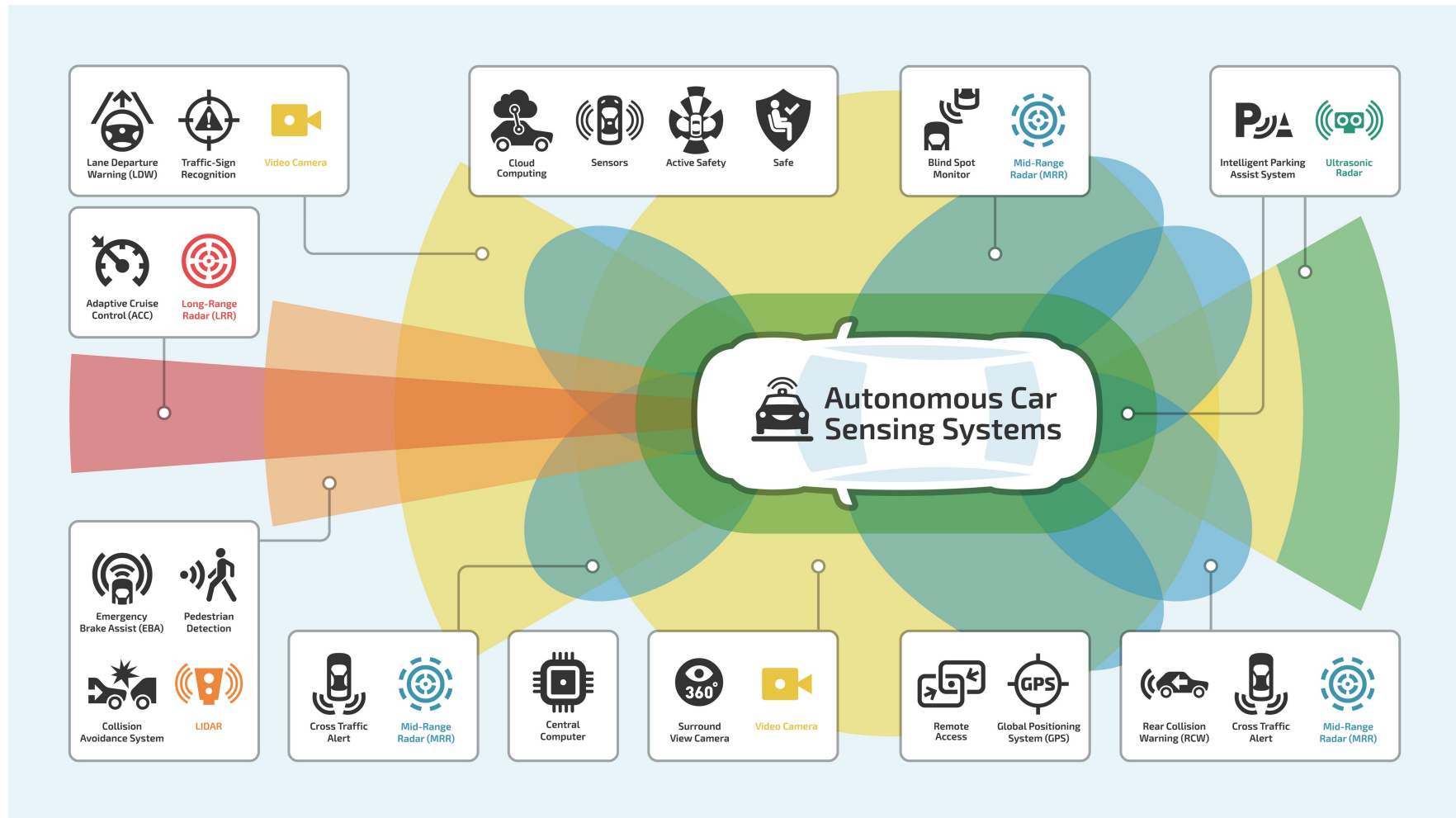
Autonomous trucking global ecosystem, 2020



Automobiles and Trucks Are E-enabled



Powered by Sensors



Increasing Autonomy

Level	Automation	Steering Cruise	Environment Monitoring	Fallback Control	Driving Modes
0	None	H	H	H	N/A
1	Supportive	H,S	H	H	Some
2	Partial	S	H	H	Some
3	Conditional	S	S	H	Some
4	High	S	S	H	Some
5	Full	S	S	S	All

TABLE I
AUTONOMOUS VEHICLES: LEVELS OF AUTONOMY (*S* - SYSTEM, *H* - HUMAN)

Society of Automotive Engineers: standard **SAE J3016** defines classes of vehicle automation

Recent Highlights

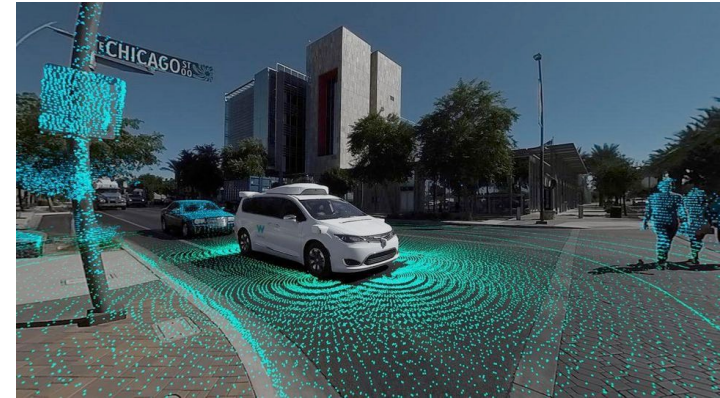


Photo Courtesy: Waymo

- **SAE J3016** has been formally validated by the US Department of Transport
- July 2024, Baidu Apollo Go has operated more than 7 Million rides
- August 2024, Mercedes Benz got L4 test approval in China
- From June 2025, Tesla will launch fully autonomous cabs in Austin, USA



Photo Courtesy: Tesla



Photo Courtesy: Mercedes

Insider Threat Impacted Traffic Management Center and Signaling



- Ghena et al, “Green Lights Forever: Analyzing the Security of Traffic Infrastructure”, USENIX 2014
- A. Greenberg, “Why the Belarus Railways Hack Marks a First for Ransomware”, Wired, January 2022

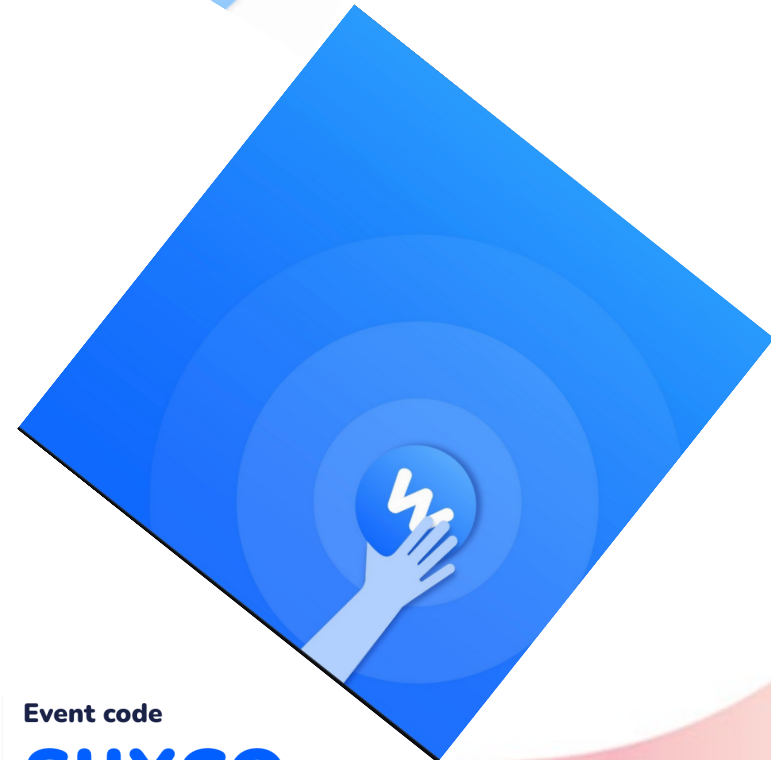


- "Tesla Model 3 Hacked in Less Than 2 Minutes at **Pwn2Own Contest**", March 2023
 - Attack I: Hacked Tesla's Gateway Energy Management System in *less than 2 minutes*
 - Attack II: Exploited a *heap overflow vulnerability* and an *out-of-bounds write error* in a *Bluetooth chipset* to break into Tesla's infotainment system and, from there, gained root access to other subsystems

Wooclap Time



wooclap



Go to wooclap.com

Enter the event code in the top banner

Event code

SIJXCQ

Contents

→ *Automotive Security Incidents*

- Attack Models and Standardization
- Security by Design
- Discussion



Go to wooclap.com

Enter the event code in the top banner

Event code

SIJXCQ

Threat Model

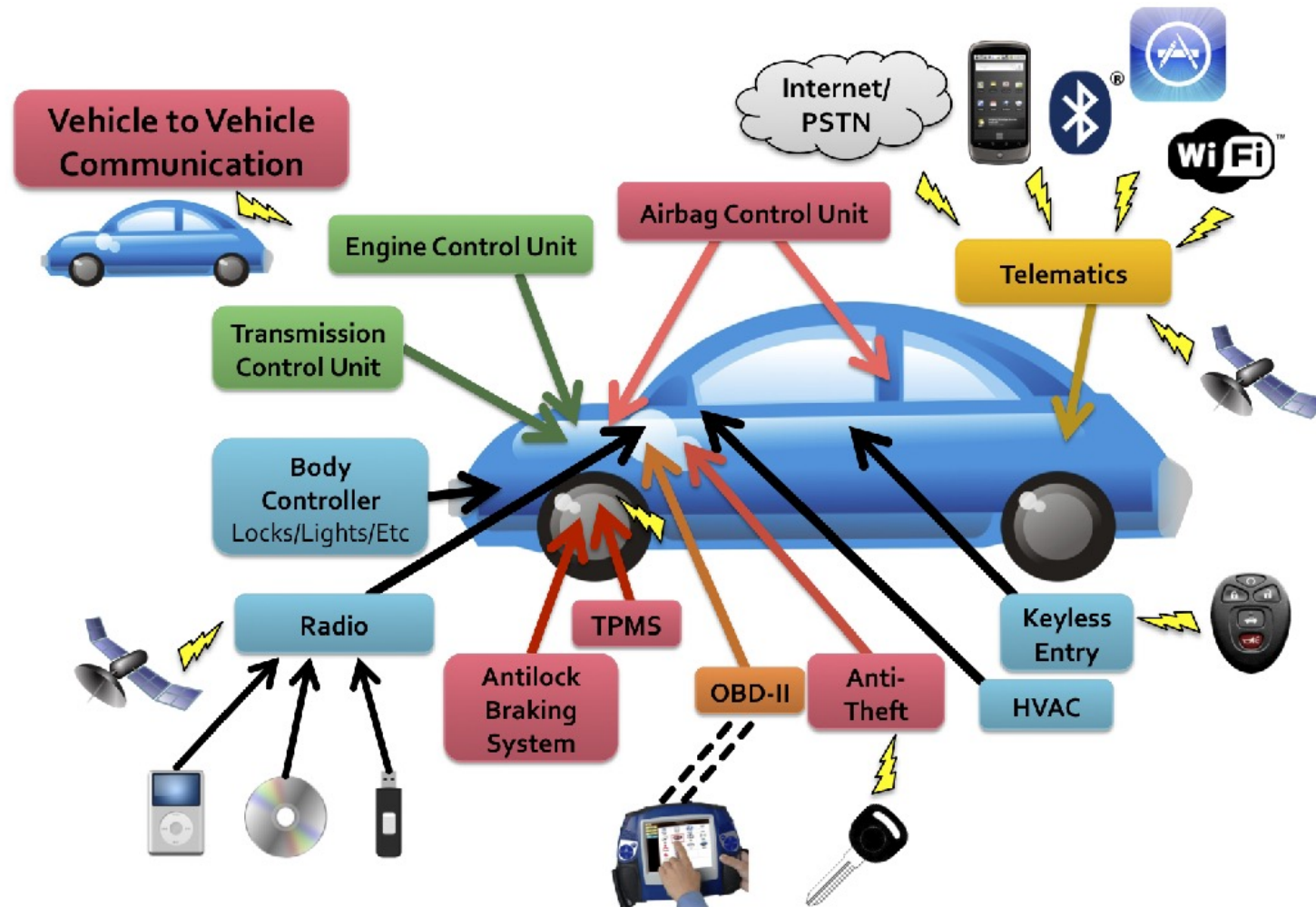
- Technical Capabilities
 - Capabilities in analyzing the system and developing exploits
- Operational capabilities
 - Analysis of attack surface of vehicles
 - How malicious payload is delivered
 - Indirect physical access, short-range wireless, long-range wireless accesses

Chekoway et al, "Comprehensive Experimental Analyses of Automotive Attack Surfaces", USENIX 2011

Vehicle attack surface

- Short-range wireless access
 - Bluetooth, Remote Keyless Entry, Tire Pressure (TPMS), WiFi
- Long-range wireless access
 - GPS, Satellite radio, Digital radio
- OBD-II
 - On board diagnostics II
 - Connects to all key CAN buses of vehicle
 - Used during vehicle maintenance
- Entertainment : Disc, USB, iPod

Vehicle attack surface

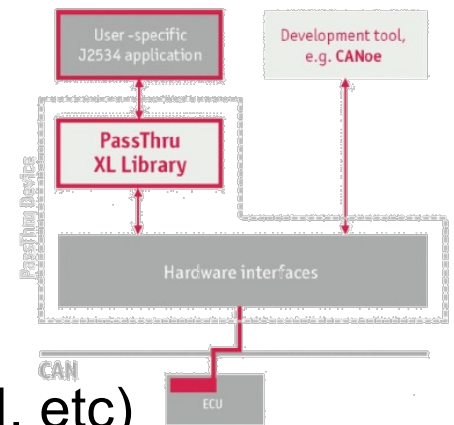


Vulnerability Analysis

- Focused on moderately priced sedan with standard options and components
- Cars < 30 ECUS comprising both critical drivetrain components & less critical components
- **PassThru** for ECU diagnosis and reprogramming

Every vulnerability allowed complete control

- General Procedure:
 - Identify microprocessor (PowerPC, ARM, Super-H, etc)
 - Extract firmware and reverse engineer using debugging devices/software where possible
 - Exploit vulnerability or simply reprogram ECU



Chekoway et al, "Comprehensive Experimental Analyses of Automotive Attack Surfaces", USENIX 2011

Exploitation Summary

Vulnerability Class	Channel	Implemented Capability	Visible to User	Scale	Full Control	Cost	Section
Direct physical	OBD-II port	Plug attack hardware directly into car OBD-II port	Yes	Small	Yes	Low	Prior work [14]
Indirect physical	CD	CD-based firmware update	Yes	Small	Yes	Medium	Section 4.2
	CD	Special song (WMA)	Yes*	Medium	Yes	Medium-High	Section 4.2
	PassThru	WiFi or wired control connection to advertised PassThru devices	No	Small	Yes	Low	Section 4.2
	PassThru	WiFi or wired shell injection	No	Viral	Yes	Low	Section 4.2
Short-range wireless	Bluetooth	Buffer overflow with paired Android phone and Trojan app	No	Large	Yes	Low-Medium	Section 4.3
	Bluetooth	Sniff MAC address, brute force PIN, buffer overflow	No	Small	Yes	Low-Medium	Section 4.3
Long-range wireless	Cellular	Call car, authentication exploit, buffer overflow (using laptop)	No	Large	Yes	Medium-High	Section 4.4
	Cellular	Call car, authentication exploit, buffer overflow (using iPod with exploit audio file, earphones, and a telephone)	No	Large	Yes	Medium-High	Section 4.4

Chekoway et al, "Comprehensive Experimental Analyses of Automotive Attack Surfaces", USENIX 2011

Indirect Physical Exploits

Media Player

- Accepts compact discs
- Software running on CPU handles audio parsing, UI functions, handles connections
- Two exploits
 1. Latent update capability of player manufacturer
 - Updates when user does nothing
 2. WMA parser vulnerability
 - Audio file parse correctly on a PC - In vehicle send arbitrary CAN packets

Indirect Physical Exploits

OBD-II

- Looked at PassThru device from manufacturer
- Found no authentication for PC's on same WiFi network
- Found exploit allowing reprogramming of PassThru
 - Allows for PassThru worm
 - Allows for control of vehicle reprogramming
 - Includes unsecured and unused Linux programs

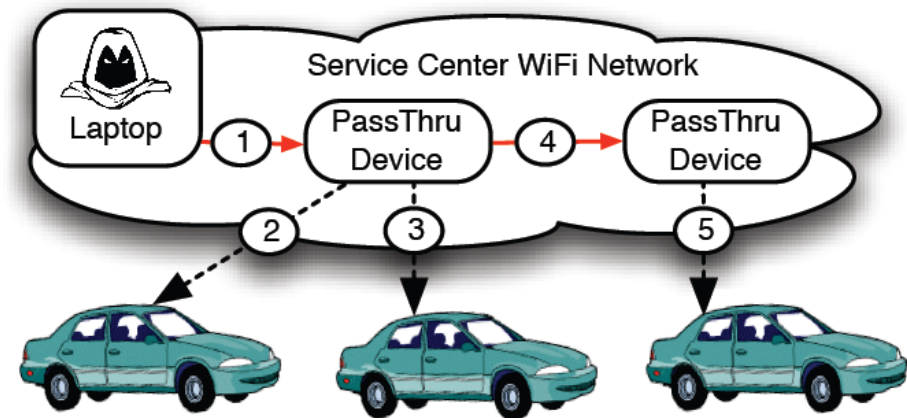


Figure 2: *PassThru-based shell-injection exploit scenario.* The adversary gains access to the service center network (e.g., by compromising an employee laptop), then (1) compromises any PassThru devices on the network, each of which compromise any cars they are used to service (2 and 3), installing Trojan horses to be activated based on some environmental trigger. The PassThru device also (4) spreads virally to other PassThru devices (e.g., if a device is loaned to other shops) which can repeat the same process (5).

Short-range Wireless Exploitation

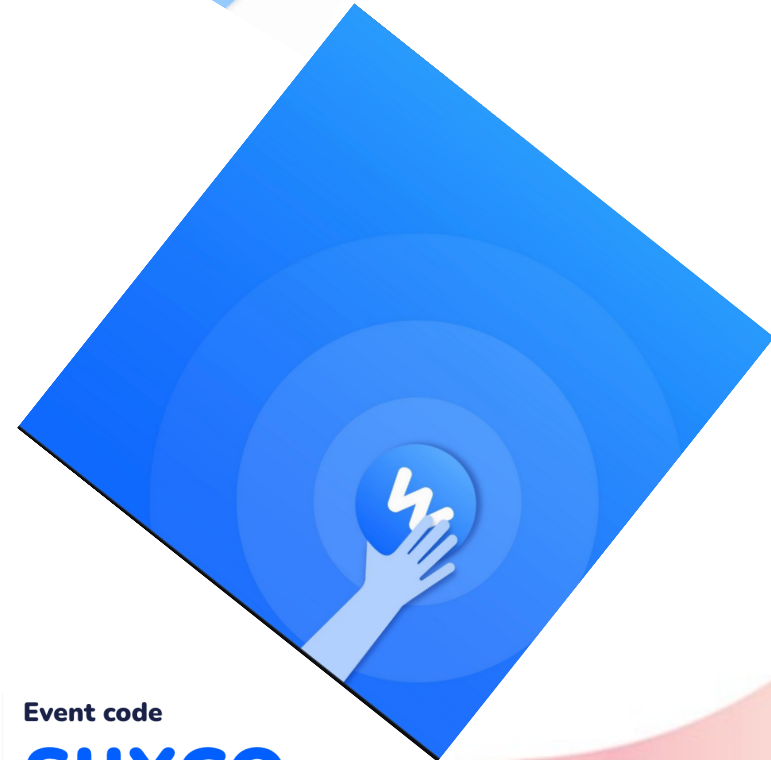
Bluetooth

- Found popular Bluetooth protocol stack with custom manufacture code on top
 - Custom code contained 20 unsafe calls to *strcpy()*
- Indirect attack → assumes attacker has paired device
 - Implemented Trojan on Android device to compromise machine
- Direct attack → exploits with a paired device
 - Requires brute force of PIN to pair device (10 hours) → Limited by response of vehicle's Bluetooth

Wooclap Time



wooclap



Go to wooclap.com

Enter the event code in the top banner

Event code

SIJXCQ

Contents

- Automotive Security Incidents

➔ *Attack Models and Standardization*

- Security by Design
- Discussion



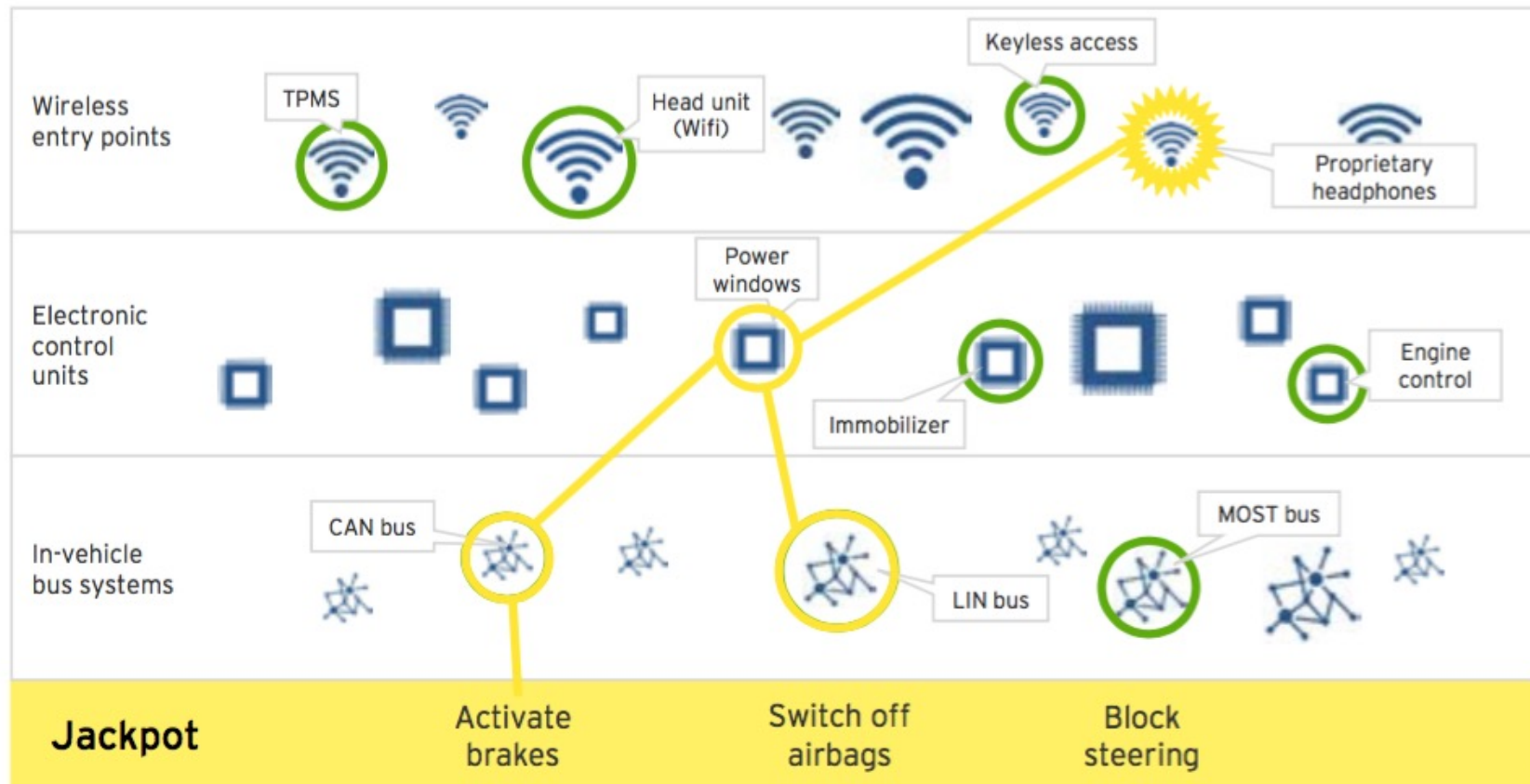
Go to wooclap.com

Enter the event code in the top banner

Event code

SIJXCQ

Exemplary Attack Path



TPMS: Tire Pressure Measurement System
CAN: Controller Area Network
LIN: Local Interconnect Network
MOST: Media Oriented Systems Transport

Automotive Cybersecurity: Problem Description



Threat motivations: Example

Theft

- Stealing sensitive information (e.g., Credit Card details)
- Deploying Ransomware
- Automotive Botnet Attack
 - Able to have cars report Vehicle Identification Number (VIN) and GPS
 - Can unlock doors, start engine and fully startup car
 - Cannot disable steering column lock

Surveillance

- Allows audio recording from in-cabin microphone
- Monitoring locations

Vulnerability: It's Complicated

- Example: the new Ford F150 pickup has **150 million lines of code**
- Each vehicle has multiple Electronic Control Units (ECUs) from different vendors
- Presents multiple attack points for hackers
- Complexity is the enemy of security



7 million lines of code

Examples of Risks

Unauthorised access to vehicles	Keyless door entry systems use mobile apps or electronic key-fobs
Theft of personal information	Owner details, GPS logs, Credit Card info, etc.
'Hijacking' of individual vehicles	Feasibility demonstrated by 'Jeep hack' (2015)
Creation of mobile 'bots'	Vehicle software compromised by hackers and used to launch cyber-attacks
Installation of 'ransomware'	Victims must pay money to regain control of their vehicles

Automotive Cybersecurity: Emerging Solutions



SAE J3061

- **“Cybersecurity Guidebook for Cyber-Physical Vehicle Systems” – published January 2016**
- Provides a framework to help organizations
 1. Identify and assess cybersecurity threats related to vehicles
 2. Design cybersecurity into cyber-physical vehicle systems throughout the entire development lifecycle process.
 3. Provides the foundation for further standards development.



OTA Updates

- “Over-the-air” software updates are crucial part of strategy
- Already implemented by vendors such as Tesla Motors
- Needs to be carefully implemented else OTA service can be hacked



Sharing of Expertise

- Automotive Information Sharing Advisory Centre (Auto-ISAC)
 - Established by the Auto industry to facilitate development of cybersecurity expertise within Automotive supply chain
 - “An industry-operated environment created to enhance cyber security awareness and coordination across the global automotive industry”
 - Published set of ‘Best Practices’ for automotive cybersecurity in July 2016

<https://www.automotiveisac.com/best-practices/>

Improve Software Quality

- Difficult to accurately estimate extent to which software code may be deemed 'buggy'
- Major initiatives designed to improve software quality
 - NIST 8151 '*Dramatically Reducing Software Vulnerabilities*'



September 2016: General Motors announced recall of 3.6 million vehicles after fear that air-bags may fail to deploy due to software fault.

NIST 8151 <http://nvlpubs.nist.gov/nistpubs/ir/2016/NIST.IR.8151.pdf>

Vulnerability fixes: Examples

- Standard security engineering best-practices e.g. don't use unsafe *strcpy* → instead *strncpy*
- Removing debugging and error symbols
- Use stack cookies and Address Space Layout Randomization (ASLR)
- Remove unused services e.g. telnet and ftp
- Authentication before re-flashing

Contents

- Automotive Security Incidents
- Attack Models and Standardization

➔ *Security by Design*

- Discussion



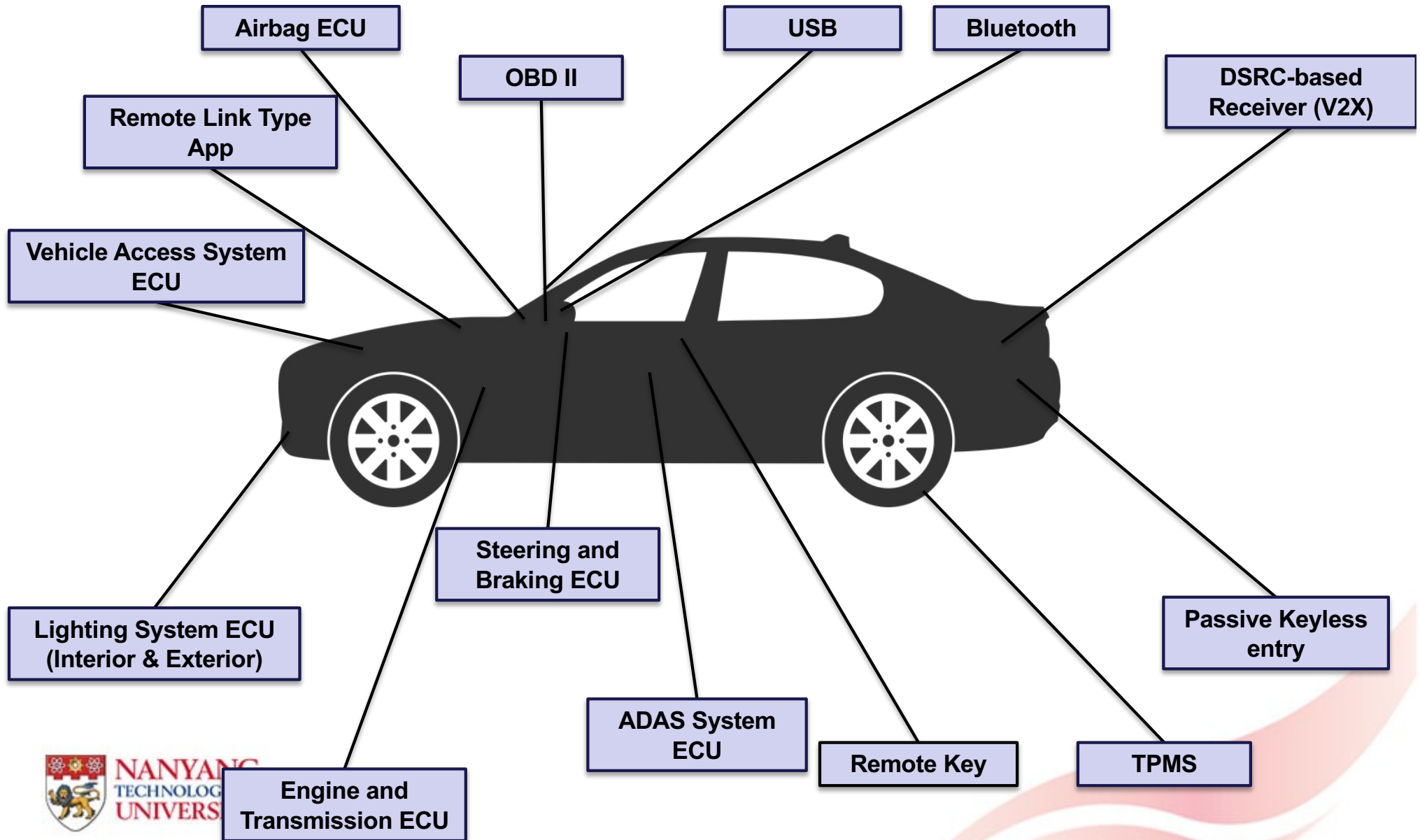
Go to wooclap.com

Enter the event code in the top banner

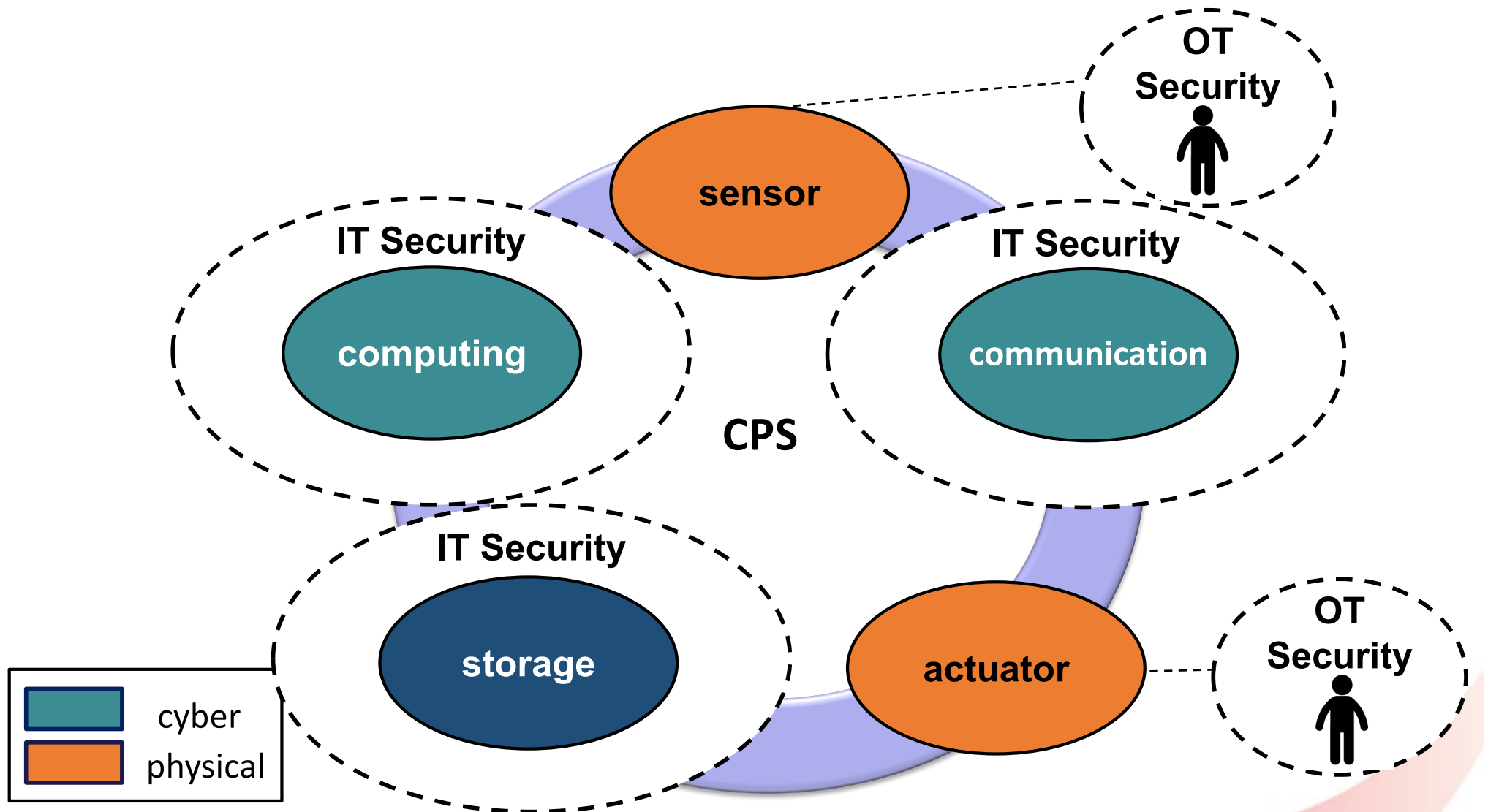
Event code

SIJXCQ

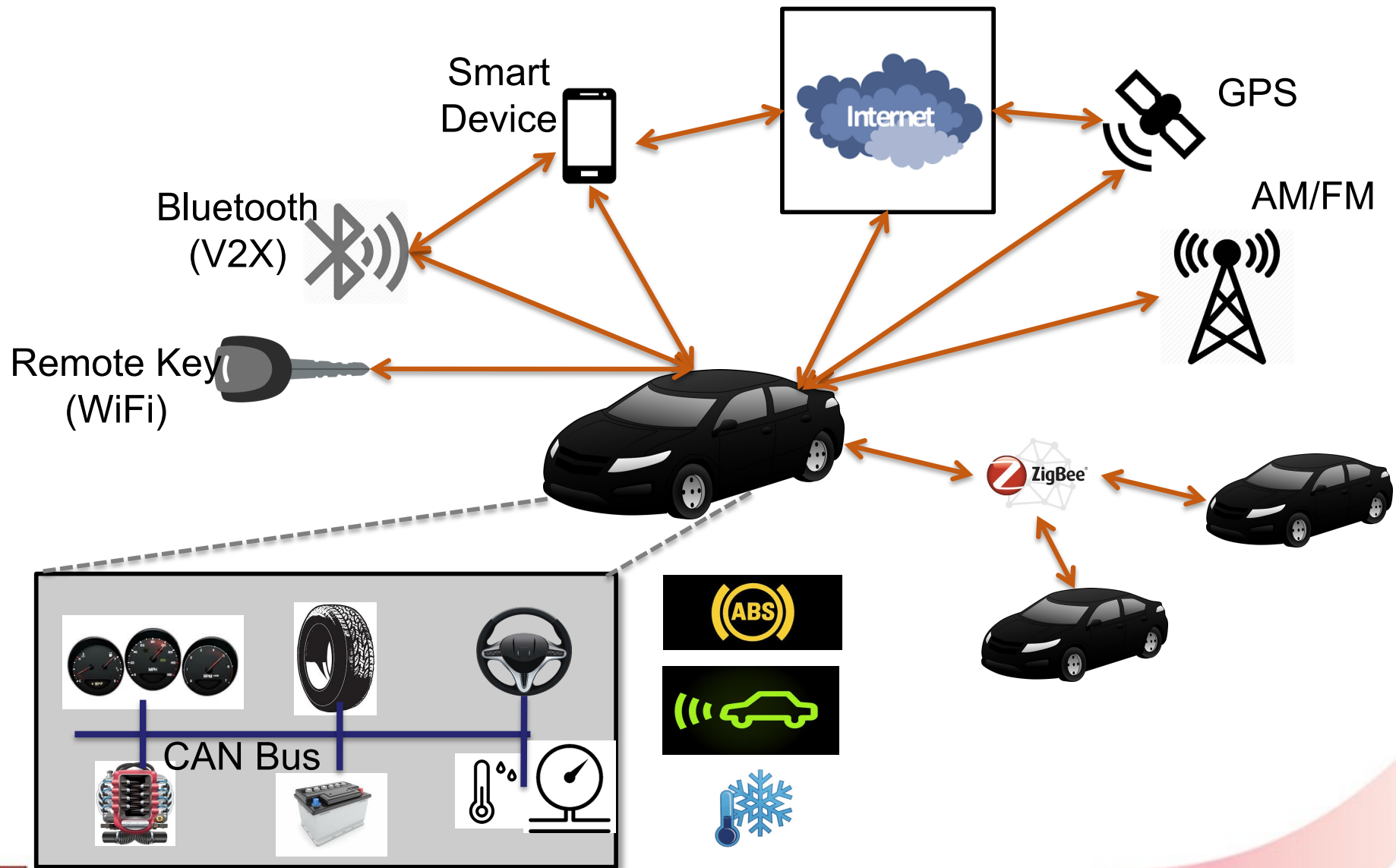
AV Attack Surfaces



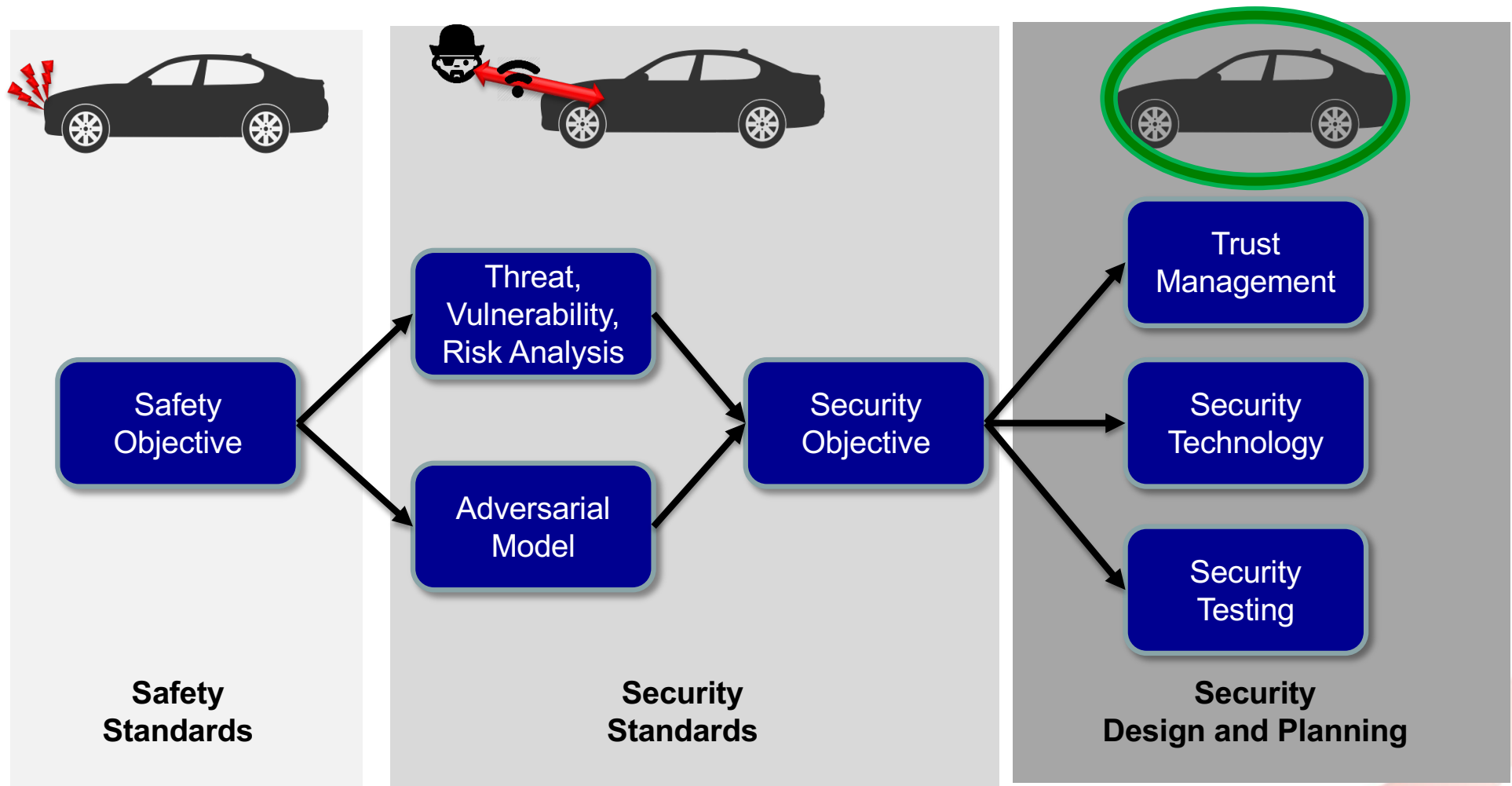
AV as CPS



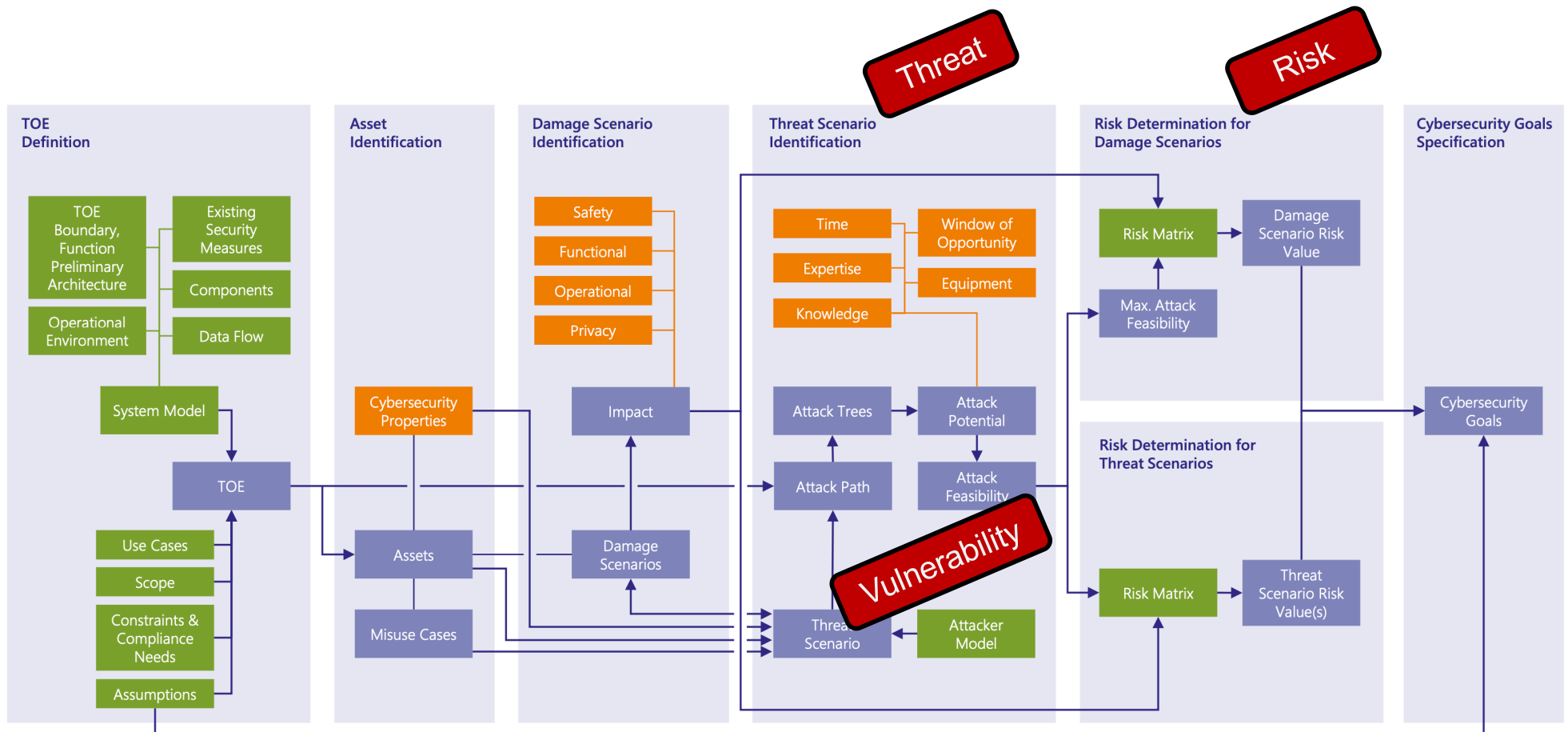
AV as IoT



AV: Safety to Security



Threat Analysis and Risk Assessment (TARA) model

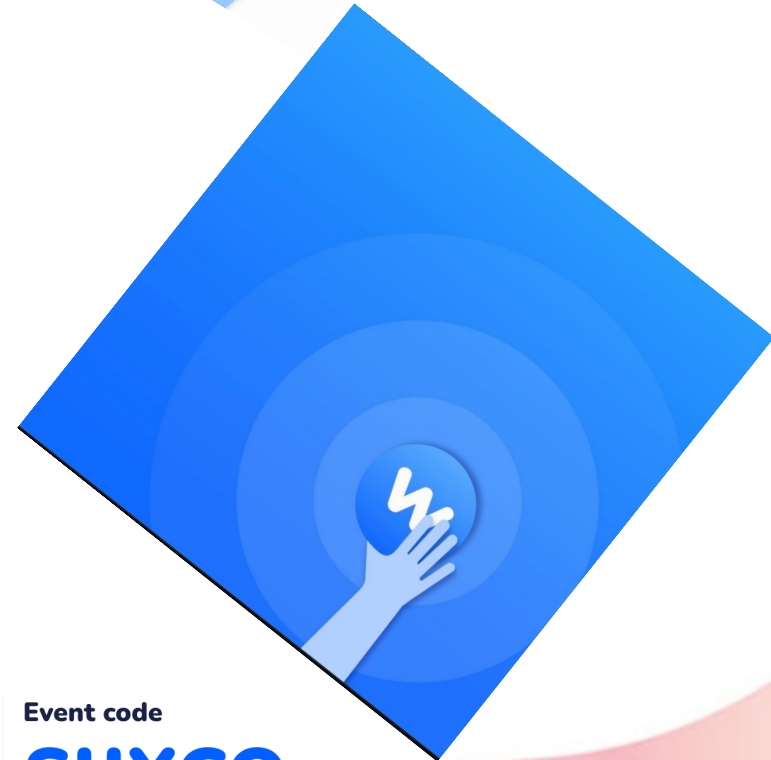


TOE: Target of Evaluation

Wooclap Time



wooclap



Go to wooclap.com

Enter the event code in the top banner

Event code

SIJXCQ

Contents

- Automotive Security Incidents
- Attack Models and Standardization
- Security by Design

→ *Discussion*



Go to wooclap.com

Enter the event code in the top banner

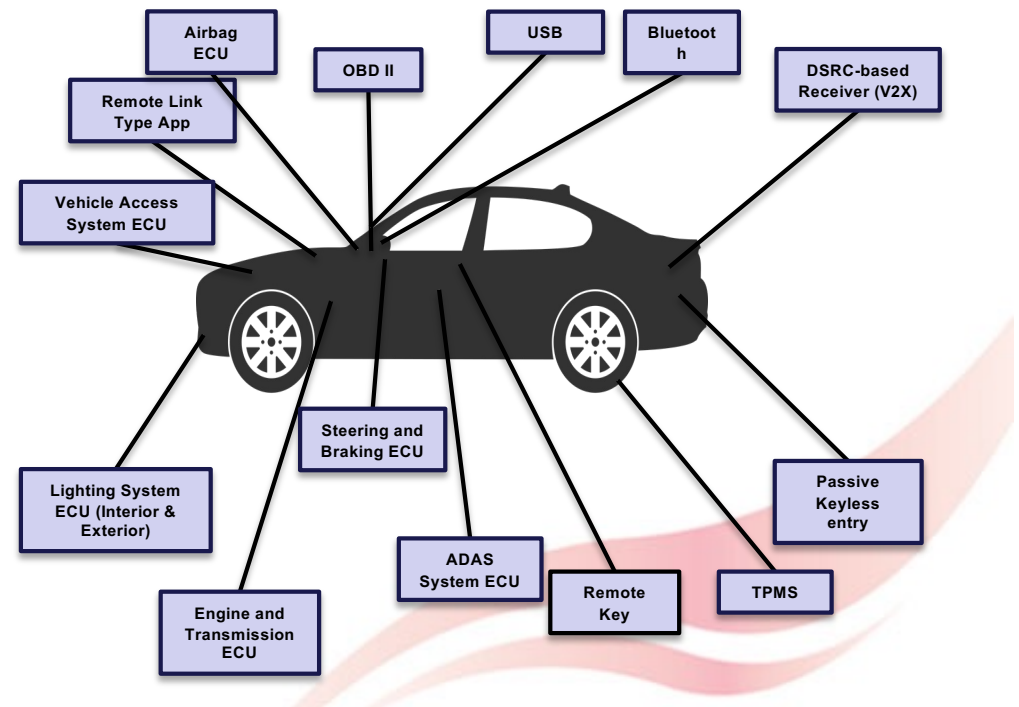
Event code

SIJXCQ

What did we learn?

- Modern automotive is surprisingly easy to attack
 - Dominantly mechatronics
 - Systematic security analysis is evolving
 - Limited understanding of modern IoT/CPS/IT attacks
 - **Critical for Autonomous Vehicles**

- Security Incidents Analysis
- Security by Design



The End



Go to wooclap.com

Enter the event code in the top banner

Event code

SIJXCQ